

CISSP Printable Practice Exam 08 - Domain 8 - Software Development Security

Domain 8

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP1-136)

Scenario: A financial services development team delivers small application increments every two weeks. Security reviewers currently examine the completed application only before a major release, and recurring authorization design flaws are causing rework.

What should the security manager recommend as the BEST way to address the recurring flaws while preserving the team's delivery model?

- A. Perform threat modeling during backlog refinement and update it when architecture or trust boundaries change.
- B. Require a full penetration test at the end of every two-week iteration before any code is merged.
- C. Move the existing security review to the user acceptance testing phase for every major release.
- D. Ask developers to document authorization defects after deployment so operations can monitor them.

Question 2 (CISSP1-137)

Scenario: A government agency has completed a technical security evaluation of a new case-management system. The evaluation confirms that required controls are implemented, but several documented residual risks remain.

Who should make the decision to permit the system to enter production?

- A. The lead developer who corrected the findings identified during testing.
- B. The assessor who performed the technical control evaluation.
- C. The designated authorizing official who can accept the residual risk.
- D. The quality assurance manager who confirmed that functional requirements were met.

Question 3 (CISSP1-138)

Scenario: A retail application contains a remotely exploitable flaw that is being actively targeted. The normal change approval board will not meet for four days, but the organization has a documented emergency change procedure.

What is the BEST course of action?

- A. Deploy the fix immediately from a developer workstation and create the change record after the next board meeting.
- B. Wait for normal approval because bypassing the regular schedule creates an unacceptable audit exception.
- C. Disable all application logging temporarily to reduce load until the normal change can be approved.
- D. Use the emergency change process, document the risk and authorization, test the fix as feasible, preserve rollback capability, and obtain retrospective review.

Question 4 (CISSP1-139)

Scenario: A software firm is moving from monthly releases to continuous delivery. Executives want to prevent high-risk defects from reaching production without turning every deployment into a manual security review.

Which control BEST supports this objective?

- A. Permit every build to deploy and rely on annual penetration testing to identify accumulated weaknesses.
- B. Define risk-based pipeline gates with automated security tests, protected overrides, and prompt feedback to developers.
- C. Require the chief information security officer to approve every source-code commit before integration.
- D. Perform security testing only in production because it most accurately represents the live environment.

Question 5 (CISSP1-140)

Scenario: A university is retiring a custom admissions application and migrating required records to a replacement service. The legacy system contains personal data, embedded service credentials, and archived source code.

Which TWO actions are MOST important for secure retirement? Select 2 of the 5 options below.

- A. Preserve every legacy account indefinitely in case historical access is needed.
- B. Verify required records were migrated and retained according to legal and business requirements.
- C. Leave the legacy environment connected but remove its link from the public website.
- D. Sanitize residual data and revoke credentials, keys, accounts, and interfaces associated with the retired system.
- E. Delete all source code immediately, including materials subject to retention or contractual requirements.

Question 6 (CISSP1-141)

Scenario: An engineering organization discovers that a developer's compromised account was used to merge unreviewed code into a protected production branch. The repository recorded the account name, but no independent approval was required.

Which improvement would MOST directly reduce the likelihood of the same event recurring?

- A. Require protected branches, independent pull-request approval, strong authentication, and restricted merge permissions.
- B. Increase the frequency of backups for the repository's underlying storage volume.
- C. Allow developers to share a release account so emergency merges are easier to coordinate.
- D. Export repository logs monthly and remove them from the active monitoring system.

Question 7 (CISSP1-142)

Scenario: During code review, an analyst finds that a web application constructs database queries by concatenating values received from request parameters. Input validation exists in the browser, but the server accepts direct requests.

What is the BEST corrective action?

- A. Add more client-side validation rules and obscure the database table names.
- B. Escape only the characters observed in the latest attack and retain string concatenation.
- C. Use parameterized queries on the server and apply server-side allow-list validation where appropriate.
- D. Encrypt the database files so injected statements cannot read stored information.

Question 8 (CISSP1-143)

Scenario: A media company learns that deployment credentials were committed to a private source repository and later copied into build logs. The repository is access-controlled, but

many contractors can read it.

Which response BEST addresses both the immediate exposure and the underlying development practice?

- A. Rename the credentials in the source file so automated scanners no longer recognize them.
- B. Remove the current line from the latest branch while retaining the same credentials for compatibility.
- C. Make the repository public so external researchers can report any additional exposed secrets.
- D. Revoke and rotate the exposed credentials, remove them from accessible history and logs, and retrieve future secrets from an approved secrets service at runtime.

Question 9 (CISSP1-144)

Scenario: A manufacturer maintains a large native-code service that has suffered repeated out-of-bounds memory defects. Rewriting the entire service is not currently feasible, but new modules are still being added.

Which strategy would provide the BEST sustainable risk reduction?

- A. Adopt memory-safe languages for suitable new modules, enable compiler and runtime protections, and prioritize review and testing of unsafe interfaces.
- B. Depend exclusively on developer training because automated controls cannot detect memory defects reliably.
- C. Disable crash reporting so attackers receive less information about exploitable conditions.
- D. Accept all existing memory defects until the organization can fund a complete rewrite.

Question 10 (CISSP1-145)

Scenario: A technology cooperative cannot determine whether a released package was produced from the approved source commit because engineers build release artifacts on individually configured workstations.

What should be implemented FIRST to establish trustworthy and repeatable releases?

- A. Allow each engineer to document local build settings in a personal procedure file.
- B. Use a controlled, isolated, reproducible build pipeline that records source provenance and signs verified artifacts.
- C. Compare the size of each release package with the previous version before distribution.
- D. Store unsigned release packages in a directory that only the development team can access.

Question 11 (CISSP1-146)

Scenario: A travel services company wants earlier detection of insecure code paths and also wants to observe authentication and session behavior while its web application is running in a test environment.

Which TWO testing approaches BEST satisfy these distinct objectives? Select 2 of the 5 options below.

- A. Static application security testing of source or compiled code during development.
- B. Dynamic application security testing against the running test application.
- C. A financial audit of software licensing expenditures.
- D. A physical inspection of the test environment's network cabling.

E. A business impact analysis of the travel reservation process.

Question 12 (CISSP1-147)

Scenario: Software composition analysis identifies a severe vulnerability in an open-source parsing library used by several internal applications. A fixed version exists, but one critical application cannot immediately upgrade because of an incompatibility.

What is the BEST response by the application security manager?

- A. Suppress the finding for all applications because one application cannot upgrade immediately.
- B. Upgrade compatible applications, assess exploitability and exposure for the exception, apply compensating controls, assign an owner and deadline, and monitor remediation.
- C. Remove the library inventory so future scans do not generate repeated findings.
- D. Replace all open-source components with internally written code before addressing the vulnerability.

Question 13 (CISSP1-148)

Scenario: A human resources department plans to acquire a cloud service that will process sensitive employee records. The provider offers a marketing security summary but will not share detailed controls, independent assessment evidence, incident obligations, or subcontractor information.

What should the security professional recommend NEXT?

- A. Approve the service because a cloud provider is responsible for every security control.
- B. Run source-code analysis against the provider's public website and treat the result as complete assurance.
- C. Perform risk-based supplier due diligence and require appropriate evidence and contractual terms before approval.
- D. Accept the marketing summary if the business owner agrees to use a strong password.

Question 14 (CISSP1-149)

Scenario: Testing shows that an authenticated customer can change an order identifier in an application programming interface request and retrieve another customer's order. The gateway correctly validates the user's access token.

Which remediation MOST directly corrects the underlying weakness?

- A. Require the API to verify on every request that the authenticated principal is authorized for the specific requested object.
- B. Increase the access token length without changing the service's authorization logic.
- C. Encode order identifiers so customers cannot easily recognize their format.
- D. Add transport encryption between the gateway and the application service.

Question 15 (CISSP1-150)

Scenario: After unauthorized business logic appeared in a production application, investigators found that deployment logs could be edited by the same administrators who performed releases and contained no reliable link to approved change records.

Which control enhancement would BEST improve future accountability?

- A. Let release administrators correct log entries after deployment so the record matches the final system state.

- B. Record only failed deployments because successful releases are already represented by the running code.
- C. Store deployment logs on each application server and overwrite them whenever storage becomes limited.
- D. Send tamper-evident deployment events to a separately controlled log system and correlate them with identities, artifacts, approvals, and timestamps.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP1-136) - Correct: A

Integrating lightweight threat modeling into backlog refinement exposes authorization and trust-boundary weaknesses while design choices are still inexpensive to change. A penetration test every iteration is usually disproportionate and occurs after design and coding decisions. Moving the same review later does not prevent rework, and documenting deployed defects transfers rather than reduces risk.

Question 2 (CISSP1-137) - Correct: C

The authorizing official makes the risk-based decision to allow operation after considering the assessment results and residual risk. The assessor provides evidence but should not accept risk on management's behalf. Developers remediate defects, while quality assurance validates functionality; neither role ordinarily has the authority to approve operation based on enterprise risk.

Question 3 (CISSP1-138) - Correct: D

The emergency procedure provides controlled flexibility for an urgent security fix while retaining authorization, testing, traceability, rollback, and later review. An undocumented direct deployment breaks configuration control. Waiting leaves an actively exploited weakness exposed, and disabling logging neither corrects the flaw nor supports incident response.

Question 4 (CISSP1-139) - Correct: B

Risk-based automated gates align security checks with continuous delivery and can stop builds that exceed defined thresholds while preserving governed exceptions. Annual testing is too infrequent, executive approval of every commit is not scalable, and relying on production testing allows preventable defects to reach live systems.

Question 5 (CISSP1-140) - Correct: B, D

Secure retirement requires proof that records needed for business or legal purposes remain available and controlled, followed by sanitization and removal of access paths such as credentials, accounts, and interfaces. Indefinite accounts and continued connectivity preserve attack surface. Immediate indiscriminate deletion may violate retention, evidence, or contractual obligations.

Question 6 (CISSP1-141) - Correct: A

Protected branches, separation through independent review, strong authentication, and least-privilege merge rights directly address unauthorized code insertion through a compromised developer account. Backups improve recoverability but do not prevent an improper merge. Shared credentials weaken accountability, and delayed offline log review does not block the change.

Question 7 (CISSP1-142) - Correct: C

Parameterized queries keep untrusted values separate from executable query structure, while server-side validation enforces expected input regardless of the client. Client-side checks can be bypassed, and attack-specific escaping is fragile. Storage encryption protects data at rest but does not prevent an authorized application connection from executing an injected query.

Question 8 (CISSP1-143) - Correct: D

Because the credentials have been exposed, revocation and rotation are necessary; cleaning accessible history and logs limits continued disclosure, and managed runtime retrieval

prevents recurrence. Renaming does not protect a secret. Removing only the latest line leaves copies and valid credentials elsewhere. Expanding repository access increases the risk.

Question 9 (CISSP1-144) - Correct: A

A layered migration strategy reduces new exposure through memory-safe implementations while hardening and scrutinizing the native-code boundary that must remain. Training is useful but insufficient as the sole control. Disabling crash reports impairs detection and diagnosis, and deferring all treatment leaves known systemic risk unaddressed.

Question 10 (CISSP1-145) - Correct: B

A controlled and reproducible pipeline ties an artifact to reviewed source and build inputs, while provenance records and signing support integrity verification after the build. Personal documentation cannot ensure identical or uncompromised environments. File size is not a reliable integrity check, and restricted storage without verification does not prove origin.

Question 11 (CISSP1-146) - Correct: A, B

Static testing can identify insecure code paths early without executing the application, while dynamic testing evaluates the exposed behavior of the running application, including session and authentication handling. Licensing audits, cabling inspections, and business impact analysis may serve other objectives but do not meet the two stated software-testing needs.

Question 12 (CISSP1-147) - Correct: B

The best response reduces risk promptly where upgrades are feasible and governs the incompatible application through an evidence-based exception, compensating controls, ownership, and a remediation deadline. A broad suppression ignores differing exposure. Removing inventory destroys visibility, and replacing all open-source code is disproportionate and delays treatment of the known vulnerability.

Question 13 (CISSP1-148) - Correct: C

Sensitive employee data warrants due diligence proportionate to the risk, including credible assurance evidence, defined responsibilities, incident terms, data handling requirements, and relevant subcontractor transparency. Cloud use does not transfer all accountability. Testing a public interface cannot establish the provider's full control environment, and a strong password does not address supplier governance risks.

Question 14 (CISSP1-149) - Correct: A

Valid authentication does not prove authorization to a particular record. The service must enforce object-level authorization for each request using the authenticated identity and requested resource. Longer tokens and encoded identifiers do not repair the missing access decision, while transport encryption protects data in transit but does not prevent an authenticated user from requesting another user's object.

Question 15 (CISSP1-150) - Correct: D

Separately controlled, tamper-evident logging reduces the ability of release administrators to alter evidence and creates an auditable chain connecting a person, approved change, deployed artifact, and time. Editable local logs lack independence, recording only failures omits critical activity, and routine overwriting undermines investigations and retention requirements.